

TRABAJO PRÁCTICO 1 - Protección de datos personales

Materia: Legislación

Unidad 10: Protección de datos personales y Habeas Data

Alumno: Nicolás Viruel

Comisión: TUPaD - UTN

Fecha: 5 de octubre de 2026

Caso

Se comprobó la difusión de datos personales en una campaña publicitaria de nuevas plataformas y cuentas de crédito, afectando a personas humanas y a algunas empresas. Se trata de un incidente de seguridad con posible tratamiento ilícito y exposición pública de información.

Roles asumidos en el plan: responsable del archivo / encargado del tratamiento (empresa que promociona créditos) y equipo técnico-jurídico que debe contener, investigar y cumplir normas.

Marco normativo de referencia

Norma / estándar | Aplicación al caso

Ley 25.326 (Habeas Data) | Principios de licitud, finalidad, calidad, seguridad y confidencialidad; derechos de titulares; deberes del responsable (arts. 2, 4, 7-10, 12-16).

Decreto 1558/2001 | Reglamentación, registro de bases, medidas de seguridad y procedimientos.

Disposición DNPDP 18/2015 (y actual AAIP) | Guías sobre seguridad de datos personales y gestión de incidentes.

GDPR (referencia comparada) | Si hubiera titulares en UE o tratamiento con alcance extraterritorial: notificación a autoridad (72 h) y a titulares cuando haya alto riesgo (arts. 33-34).

ISO/IEC 27001:2022 | SGSI: gestión de riesgos, controles organizacionales y técnicos.

ISO/IEC 27035 | Gestión de incidentes de seguridad de la información (contención, análisis, erradicación, recuperación, lecciones aprendidas).

Plan de respuesta legal y operativa

Fase 1 - Contención inmediata (0-24 h)

1. Suspender la campaña publicitaria y cualquier pieza que muestre datos reales (banners, mails, redes, landings).
2. Revocar accesos, tokens y permisos de quienes intervinieron en el armado de la campaña; rotar credenciales de APIs y bases usadas para segmentación.
3. Preservar evidencia para auditoría: logs, exportaciones, versiones de creativos, backups (cadena de custodia interna, sin alterar originales).
4. Designar responsable del incidente (CISO / referente de datos) y canal único de comunicación interna.

Referencia: ISO/IEC 27035 (contención); Ley 25.326 art. 9 (medidas de seguridad acordes al riesgo).

Fase 2 - Evaluación del alcance (24-72 h)

1. Inventariar qué datos se expusieron (identificación, contacto, situación crediticia, CUIT/CUIL, datos de empresas).
2. Clasificar sensibilidad y volumen de titulares afectados.
3. Determinar base legal del tratamiento original y si la finalidad publicitaria estaba autorizada.
4. Revisar si hubo cesión a terceros (agencias, plataformas) sin consentimiento o contrato de encargado.

Referencia: Ley 25.326 arts. 4 (calidad y pertinencia), 5 (finalidad), 11 (cesión); ISO/IEC 27001 control de inventario de información (Anexo A).

Fase 3 - Notificaciones y derechos de titulares

1. Interno: informar a dirección y asesoría legal; evaluar seguro de ciberriesgos si existe.
2. Autoridad de control: en Argentina, comunicar el incidente a la Agencia de Acceso a la Información Pública (AAIP), sucesora de la DNPDP en la protección de datos personales, con descripción del hecho, datos afectados y medidas adoptadas (según criterios administrativos y deber de colaboración con la autoridad).
3. Titulares: cuando el riesgo lo justifique, informar a personas y empresas afectadas de forma clara: qué ocurrió, qué datos, qué hicieron para mitigar y cómo ejercer derechos de acceso, rectificación, supresión y Habeas Data (arts. 14-16 Ley 25.326).
4. Si hay titulares en UE, evaluar notificación bajo GDPR art. 33-34 en coordinación con DPO o asesor externo.

Fase 4 - Remediación técnica y organizativa

1. Minimización: dejar de usar datos reales en entornos de prueba o demos; usar datos anonimizados o sintéticos.
2. Controles de acceso: principio de mínimo privilegio, MFA, segregación entre marketing y bases productivas.
3. Cifrado en tránsito y reposo para bases con datos crediticios o identificadores.
4. Políticas de uso aceptable para campañas; revisión jurídica previa de creativos con datos.
5. Acuerdos con encargados del tratamiento (agencias, SaaS) con cláusulas Ley 25.326 y confidencialidad.

Referencia: ISO/IEC 27001 (controles de acceso, criptografía, proveedores); Disposiciones AAIP sobre medidas de seguridad.

Fase 5 - Seguimiento y prevención

1. Registro del incidente y lecciones aprendidas (informe post-incidente).
2. Capacitación a marketing y desarrollo en protección de datos y uso de entornos de prueba.
3. Auditoría o revisión del SGSI; actualizar matriz de riesgos.
4. Evaluar responsabilidades civiles (daños a titulares) y posibles denuncias penales si hubo acceso indebido doloso (Ley 26.388 / arts. 153 bis y 157 bis CP).

Criterio profesional (cierre)

Como técnico en programación, la fuga en una campaña suele nacer de copiar datos productivos a un entorno de marketing, de permisos mal dados o de creativos armados con información real. El plan combina acción urgente (cortar difusión), cumplimiento (AAIP, titulares, Habeas Data) y estándares (ISO 27001 / 27035) para que la respuesta sea defendible ante auditoría y ante los afectados, sin minimizar el incidente ni prometer “cero riesgo” donde la ley exige transparencia.